Design privileged access that expires



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com





Checking in with Globomantics



Eleven standing global administrators, nine unexplained

The break-glass account lives inside the forest it recovers

Maintenance vendors hold VPN access to plant networks

Which one do you fix first, and what breaks if you're wrong?

Tier privileged access with the enterprise access model

Contain the compromise by separating the planes

Control plane: identity systems and access control itself

Management plane: enterprise-wide IT management functions

Data and workload plane: per-workload administration and business value

Microsoft Learn, enterprise access model

“Each of these planes has control of the data and workloads by virtue of their functions, creating an attractive pathway for attackers to abuse if they can gain control of either plane.”

Citation: Microsoft, “Enterprise access model”, learn.microsoft.com/security/privileged-access-workstations/privileged-access-access-model

Make privilege temporary and its acquisition observable

One lifecycle, not three features



Entitlement management automates the request and its approval path

Microsoft Entra Privileged Identity Management governs the activation

Access reviews validate what the other two granted

Assess Active Directory resilience to common attacks

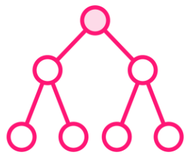
Evaluate the forest like an attacker already has



Resilience to credential theft and lateral movement is the test, not a scan



Cloud-side hygiene doesn't remediate an on-premises trust



The inherited forest is the live case, and it still trusts production

Secure tenant administration across SaaS and multicloud

Every platform has its own idea of an administrator

SaaS apps, AWS, and GCP each carry separate privileged roles

No single console shows all of them together

Design one standard for admin access, then map it per platform

Find the permissions nobody uses

Granted permissions accrue, used permissions don't



Cloud infrastructure entitlement management finds the gap between them

Delivered through Microsoft Defender for Cloud, across Azure, AWS, and GCP

The gap is your cheapest risk reduction: revoke what nobody uses

Tell an access review apart from an entitlement control

Reviews sample, entitlements accrue

Access review	vs.	Entitlement control
Samples on a schedule		Governs the grant continuously
A person confirms or revokes		Policy decides at request time
Catches drift after it happens		Prevents drift before it starts
Evaluate: reviewer, stage duration, no-response outcome		Evaluate: approval path, expiration, scope

Administer from a privileged access workstation

The workstation is part of the control plane

Administration from a general-purpose device undoes every other control

A privileged access workstation is hardened, dedicated, and boring

Remote and vendor access earns a governed path, with phishing-resistant authentication

Demo: Measure the eleven-administrator problem

Review privileged role assignments and elevation evidence in the Microsoft Entra admin center, then read permissions findings in Microsoft Defender for Cloud

Relevant SC-100 practice question

Recover when the acquired forest is down

Question

The break-glass account lives in the acquired forest, the estate most likely to be compromised. No second forest this year.

A. Enroll the break-glass account in PIM

B. Emergency accounts in Entra ID, excluded and monitored

C. Tier zero plus a privileged access workstation

D. Rotate the credential monthly with the platform team

Recover when the acquired forest is down

Answer: B

The break-glass account lives in the acquired forest, the estate most likely to be compromised. No second forest this year.

A. Enroll the break-glass account in PIM

B. Emergency accounts in Entra ID, excluded and monitored

C. Tier zero plus a privileged access workstation

D. Rotate the credential monthly with the platform team

Checking out with Globomantics



Separate the planes, and let no account span them

Make privilege eligible, activated, and reviewed as one lifecycle

Find and revoke the permissions nobody uses

Administer from hardware that does nothing else